INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)

Course 2: GRC102: Information Security Governance

Deep Dive into Security Governance:

Roles, Responsibilities, and Real-World Application

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 06/09/2025

Roles, Responsibilities, and Real-World Application

Executive Summary:

We examine the evolving role of the CISO, shifting from a purely technical function to a strategic leadership position. Based on insights from sources like ISC2, TechTarget and Klogix, we highlight how today's CISOs are expected to engage directly with executive leadership and boards helping shape business-aligned security strategies. We also analyze positive case study of CISO Change focusing on Safaricom, Kenya's leading telecommunication provider. We also explore a real-world breach of Kenya's eCitizen platform. Based on data provided, we explore security incident from NDPC, identifying key risks and cost drivers in NDPC's incident response. We also provide three actionable recommendations to strengthen governance, risk management and compliance based on the data analysis.

The CISO's Evolving Role:

How the CISO Role Has Evolved Over the Past Decade:

Over the past ten years, the role of the Chief Information Security Officer(CISO) evolved and changed greatly. Viewed more of a technical job focused on managing firewalls, stopping malware, and responding to security incidents, most CISOs worked within ICT Department, mainly focused on keeping systems secure behind the scene.

CISOs are now seen as key business leaders, not just technical experts. According to TechTarget (Murphy, 2025), modern CISO is expected to think strategically, manage risk at company-wide level, and support business innovation while keeping everything secure. They no longer work behind scenes, protecting network, they are now helping in guiding the entire business through digital world safely.

What Led to The Role Change?

Reasons that advised the role change majorly tied to the growing cyber threat landscape. Attacks like ransomware, phishing, and supply chain hacks have become more common and damaging. At the same time, companies going digital and the uptake of digital tools like cloud services, third party platforms and Artificial Intelligence creates more risk. ISC2(Singh, 2024), points out with digitization, CISOs have to protect more than in-house systems, they also need to focus on data and services that live everywhere, across different teams, vendors, geographical location (Countries and Jurisdictions).

Another factor leading to the change is the board-level scrutiny. Company executives and members now view cybersecurity as a top business risk and not another IT problem. As a result, many CISOs are now reporting directly to the CEO or to the board instead of the CIO. Klogix (2025) shows 82% of CISOs now report to CEO and 83% regularly present to the board. This gives more influence but also adds pressure to clearly explain security risks in business terms.

How Responsibilities Have Expanded:

Today's CISOs have expanded range of responsibilities. Besides traditional security tasks, they now manage:

- Enterprise Risk Management
- Compliance with laws and regulations like GDPR and most recently AI rules.
- Cloud and Vendor security
- Privacy concerns
- Incidence response planning
- Responsible AI usage and monitoring
- Security awareness training

They also work closely with other departments, to make sure security is part of business decision. ISC2(2025a) emphasizes that leadership, communication and strategy are now as important as technical skills.

Summary:

In the past, CISOs were mainly technical experts working behind the scenes. Today, they are strategic leaders shaping company direction, managing risk, and working closely with executive team. Their job is complex and demanding than ever, it is also more important to the success of the entire organization.

Real-World Example of a CISO's Impact on an Organization's Security Posture

A strong example of a positive CISO impact is from Safaricom, Kenya's leading telecommunication provider. Safaricom has a dedicated CISO playing key role in the organization's overall security strategy. What makes this case stand out is that the CISO reports to a Cybersecurity and Technology Committee, which includes senior management and board members. This reporting structure allows the CISO to influence decisions at highest level, ensuring cybersecurity is treated as a business critical function and not reduced to technical. As a result, the CISO has authority and visibility to drive improvements in areas like risk management, vendor oversight, incident response planning and regulatory compliance.

According to a 2023 academic study, Safaricom's approach has helped strengthen its information security management system(ISMS), leading to better protection of customer data, stronger internal controls and

improved trust in digital services. This shows giving the CISO proper leadership access and governance support makes real difference in an organization's security posture.

Case Study Analysis:

eCitizen DDoS Attack (Kenya, 2023): Security Governance Analysis:

a. **Brief Overview of the Security Breach**

In July 2023, Kenya's eCitizen platform, hosting government services including passport application, business registration and tax payment, experienced a DDoS attack. The attackers flooded the platform with excessive traffic, causing downtime and service disruptions for several days (The Star, 2023). Although no personal data was stolen, the attack affected digital service delivery, including access to mobile payments like M-Pesa (Business Daily Africa, 2023). A group calling itself "Anonymous Sudan" claimed responsibility.

b. **Security Governance Structure before the Breach**

The auditor-general report revealed that Kenyan government lacked full administrative control over eCitizen platform. The platform was operated by third-party vendor, government did not have access to system's source code, administrative privileges or technical documentation (Tuko News, 2023), creating single point of failure, limiting the government's ability to monitor, audit or secure the platform effectively.

There was also no publicly known cybersecurity committee, CISO oversight, or structured reporting channels between security teams and executive leadership, indicating a weak or non-existent security governance framework.

c. **Assessment of Governance Failures or Weakness:**

Several key governance failures contributed to the incident:

- Lack of ownership and control: The platform's critical infrastructure was not under direct government management creating dependencies and response delays (Nation Africa, 2023)
- Absence of formal cybersecurity governance model: no evidence of CISO, cybersecurity strategy or regular risk assessments.
- Limited monitoring and Visibility: auditor-general noted that government could not assess system performance, cyber risks, or audit logs due to vendor lock-in (Tuko News, 2023).
- Poor board-level oversight: Executive leadership appeared unaware of risks posed by existing governance setup, demonstrating gap in strategic involvement and risk management.

d. **Regulatory and Financial Consequences**

The breach had both regulatory and financial consequences:

- Regulatory Exposure: auditor-general's report brought public attention to serious compliance and operational risks, including loss of revenue accountability and cybersecurity exposure (Capital FM, 2025)
- Financial Impact: Service outages led to interruption of payments and revenue collection, affecting both citizens and government operations. Allegations of over KES 10 billion unaccounted transactions, damaging trust in the platform (Capital FM,2025)

No official fines were issued, the public and media scrutiny prompted urgent reviews of how digital services are managed.

e. Recommendations for Improved Security Governance:

To prevent similar incidents, following recommendations are proposed:

1. Establish formal cybersecurity governance structure: create a national cybersecurity oversight
2. Reclaim full ownership and control: government must obtain all administrative rights, system documentation, and platform's source code from vendor to reduce risk.
3. Implement continuous monitoring and threat detection: adopt real-time traffic analysis, DDoS mitigation tools, and a security operations center (SOC) to detect and respond quickly.
4. Strengthen Infrastructure resilience: develop redundant systems, backup servers and failover strategies to ensure service continuity even during attacks.
5. Board-level cybersecurity training: provide cybersecurity awareness training to senior executives
6. Require regular data protection Impact Assessment and third party audits to identify and fix vulnerabilities proactively.

f. Conclusive Summary:

The eCitizen breach highlights how critical cybersecurity governance is for digital public infrastructure. Lack of ownership, monitoring, and executive oversight left the platform vulnerable. By establishing clear governance structures, strengthening infrastructure and giving cybersecurity a seat at the leadership table, Kenya can better protect its digital services.

Data Analysis and GRC Application (NDPC Case Study)

Total number of incidents and the distribution of incidents by *Incident_Type*:

Below table summarizes the distribution of the incidents, a Pivot Table analysis shows a total of 100 incidents broken down to type.

Incident_Type	Count of Incident_ID
Data Leak	20
Unauthorized Access	20
Malware	19
Phishing	16
DDoS	15
Misconfiguration	10
Grand Total	**100**

Average *Resolution_Time_Days* for incidents, broken down by *Severity*:

With the summary below using a Pivot Table, the average resolution time for incidents was analyzed based on severity.

Severity	Average of Resolution_Time_Days
Low	13.29
Critical	13.92
High	15.77
Medium	15.98
Grand Total	**15.21**

Total *Cost_Impact_USD* by *Department* and *Responsible_Team*:

The analysis based on the Pivot table shows the total financial impact of incidents, categorized by both department and responsible team.

Sum of Cost_Impact_USD	Responsible Team				
Departments	Compliance	IT Security	DevOps	SOC	Grand Total
Finance	$ 590,927.00	$ 329,030.00	$ 228,778.00	$ 222,197.00	$ 1,370,932.00
Legal	$ 490,686.00	$ 306,203.00	$ 299,985.00	$ 105,740.00	$ 1,202,614.00
IT	$ 249,581.00	$ 267,515.00	$ 333,607.00	$ 262,962.00	$ 1,113,665.00
HR	$ 193,731.00	$ 319,030.00	$ 237,920.00	$ 128,521.00	$ 879,202.00
Operations	$ 191,374.00	$ 130,195.00	$ 219,916.00	$ 226,084.00	$ 767,569.00
Grand Total	**$ 1,716,299.00**	**$ 1,351,973.00**	**$ 1,320,206.00**	**$ 945,504.00**	**$ 5,333,982.00**

Top 3 *Incident_Type* categories with the highest average *Cost_Impact_USD*:

After analyzing the average cost of different types of security incidents using a Pivot Table, we find that the top three incidents types with the highest average cost impact are as below: Malware, Misconfiguration, and Unauthorized Access.

Incident_Type	Average of Cost_Impact_USD
Malware	$ 58,167.00
Misconfiguration	$ 56,787.30
Unauthorized Access	$ 55,452.95
DDoS	$ 54,946.60
Data Leak	$ 49,205.85
Phishing	$ 46,472.56
Grand Total	**$ 53,339.82**

Percentage of incidents with *Status* as 'Open' or 'In Progress':

Based on the data below, 17% of incidents are currently marked as open, and 14% are in progress, making a combined total of 31% of all incidents still active.

B10 =17+14

Row Labels	Count of Incident_ID
Closed	60.00%
In Progress	14.00%
On Hold	9.00%
Open	17.00%
Grand Total	**100.00%**
Total Open and Inprogress	31

Visual Representation of Data:

1. The Chart1 Below is a pie chart showing distribution of incidents by status.

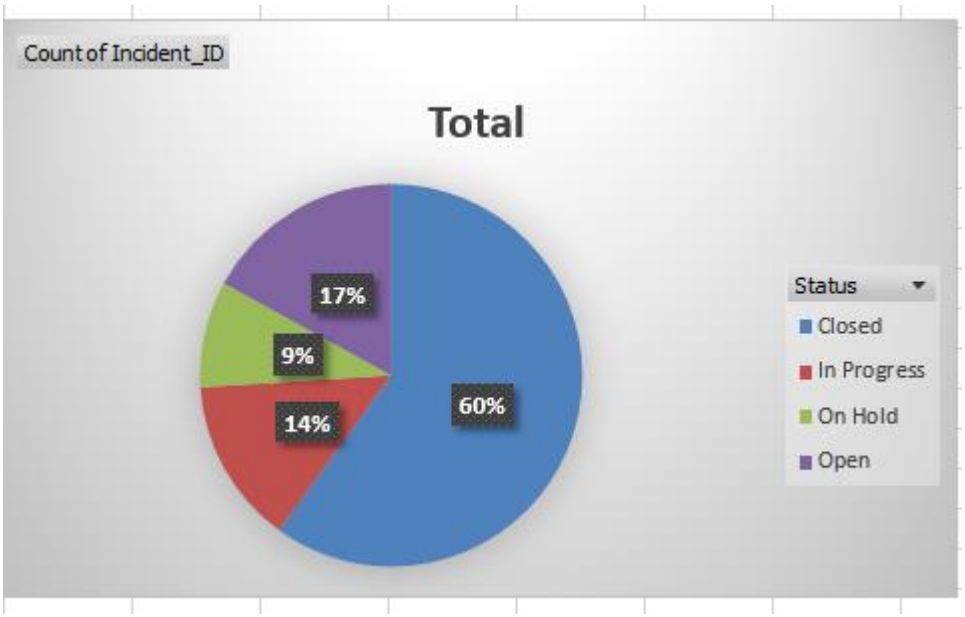

Chart1: Pie chart

2. The chart 2 below is showing the average cost impact per incident type.

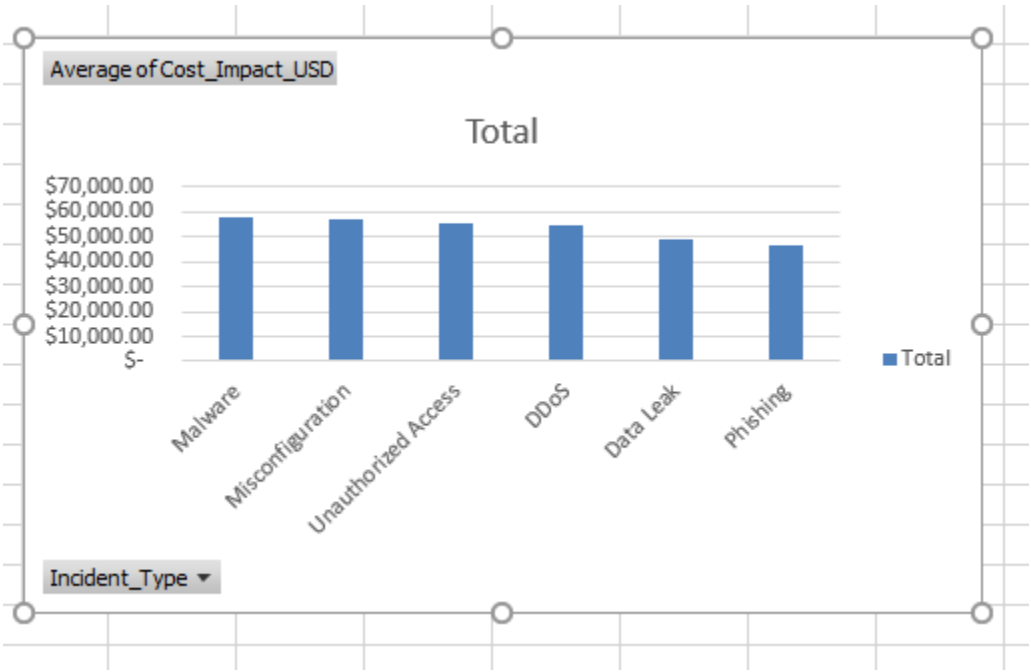

Chart 2: Bar Chart

Three Most Critical Insights

Insight1: High Average Cost of Malware and Misconfiguration Incidents:

Data Insights:

Malware incidents, had the highest average cost at $58,167 followed closely by misconfiguration and unauthorized access. This could be an indication of insufficient preventive controls or configuration management practices.

Recommendations:

Implementing stricter vulnerability and configuration management program. Inclusive of automated patching, continuous configuration monitoring, stronger anti-malware defenses and higher focus given the departments most affected.

Governance Link:

This aligns with CISO' role in risk prioritization and control implementation. The board and executive leadership also require regular reporting on high-impact incident categories as part of oversight responsibilities.

Insight 2: 31% of Incidents Open

Data Insight:

Out of 100 incidents, 17 open, and 14 in progress, meaning 31% of incidents are unresolved (excluding the 9% that are on hold). This could be due to resource constraint, poor incident tracking or unclear resolution workflows.

Recommendation:

NDPC should streamline process for incident response enforcing SLAs for resolution time. It could also benefit from introducing automated ticket tracking and escalating workflows to reduce backlog.

Governance Link:

Ensuring timely resolution of incidents is key performance area of CISO, supporting governance principles like accountability, timely risk mitigation and transparency in operations.

Insight 3: Compliance and IT Security Teams carry Highest Cost Impact:

Data Insight:

Compliance followed by IT Security accounted for highest total impact at $1.7M and $1.35M respectively. This suggests that the teams are either overloaded or responding late to incidents.

Recommendation:

Reassess distribution of incident response responsibilities. CISO should lead realignment of GRC role in the organization, ensuring there is better coordination between various teams, with a committee overseeing this.

Governance Link:

Working role clarity and cross-functional collaboration are part of best practice in GRC. CISO plays a strategic role in ensuring that governance structures are in place and are effective and responsive to trends in risk.

Insight Summary:

The insights highlighted are a reflection of actual incident data, it shows where NDPC can improve the strategy of the GRC. Focusing on high-cost incident types, reducing resolution delays and optimizing team responsibilities, the executive leadership with guidance from CISO can improve the security posture at NDPC and align with modern governance expectation.

Reference:

Murphy, J. (2025, June). ***The CISO evolution: From security gatekeeper to strategic leader*****. TechTarget.** https://www.techtarget.com/searchsecurity/feature/The-CISO-evolution-From-security-gatekeeper-to-strategic-leader

Klogix Security. (2025, August). ***The evolving role of the CISO*****.** https://www.klogixsecurity.com/blog/the-evolving-role-of-the-ciso

ISC². (2025a, February). ***The juxtaposition of the modern CISO role*****.** https://www.isc2.org/Insights/2025/02/the-juxtaposition-of-the-modern-ciso-rule

ISC². (2024, February). Singh, G. ***How has digitalization changed the role of the CISO?*** https://www.isc2.org/Insights/2024/02/How-Has-Digitalization-Changed-the-Role-of-the-CISO

ISC². (2024, December). ***Cybersecurity leadership skills survey & workshop*****.** https://www.isc2.org/insights/2024/12/isc2-leadership-workshop-and-survey

Mutiso, F. M., & Wabwoba, F. (2023). ***Information security management system practices in Kenya: A case of Safaricom PLC.*** **International Journal of Management Science and Business Administration, 9(2), 1–7.** https://researchleap.com/information-security-management-system-practices-in-kenya/

Business Daily Africa. (2023, July 28). ***Hackers shake Kenya's digital financial system*****.** https://www.businessdailyafrica.com/bd/corporate/technology/hackers-shake-kenya-s-digital-financial-system--4318466

Capital FM. (2025, August 4). ***Sh10.8bn eCitizen black hole: Governance gaps, murky deals and irregular payments*****.** https://www.capitalfm.co.ke/business/2025/08/sh10-8bn-ecitizen-black-hole-governance-gaps-murky-deals-and-irregular-payments

Nation Africa. (2023, July 30). ***Private firms running eCitizen platform – Auditor-General*****.** https://nation.africa/kenya/business/private-firms-running-e-citizen-auditor-general-nancy-gathungu-says-4532910

The Star. (2023, July 27). ***CS Owalo confirms hack on eCitizen platform, no data lost*****.** https://www.the-star.co.ke/news/2023-07-27-cs-owalo-confirms-hack-on-ecitizen-platform-no-data-lost

Tuko News. (2023, August 1). ***Auditor General warns eCitizen vulnerable as gov't lacks full control of system*****.** https://www.tuko.co.ke/business-economy/technology/538926-auditor-general-warns-ecitizen-vulnerable-risks-govt-fully-control-system